Defense in Depth

Company -
host SAAS Platform

Goal -
Customer Database

INTERNET
EDGE ROUTER
FIREWALL
DMZ (Web Server)
APP SERVER
DATABASE
Employee Network

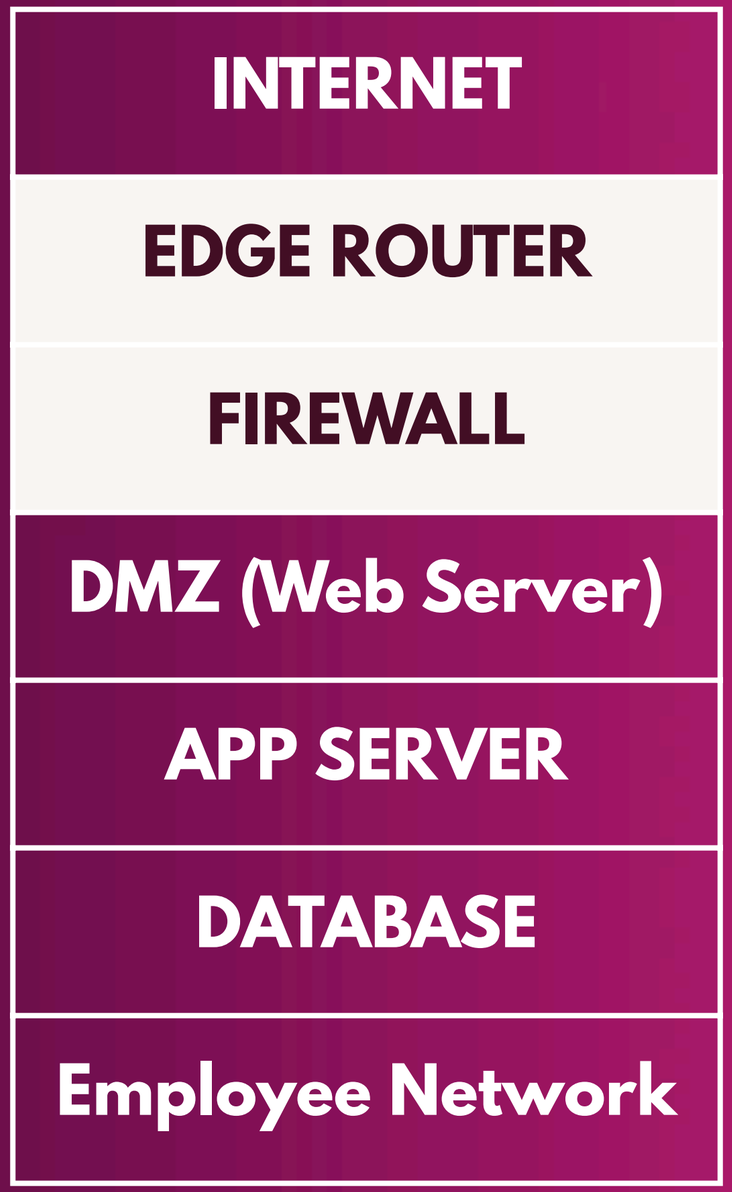
Reconnaissance

- Port Scan
- Open Services

} attacker

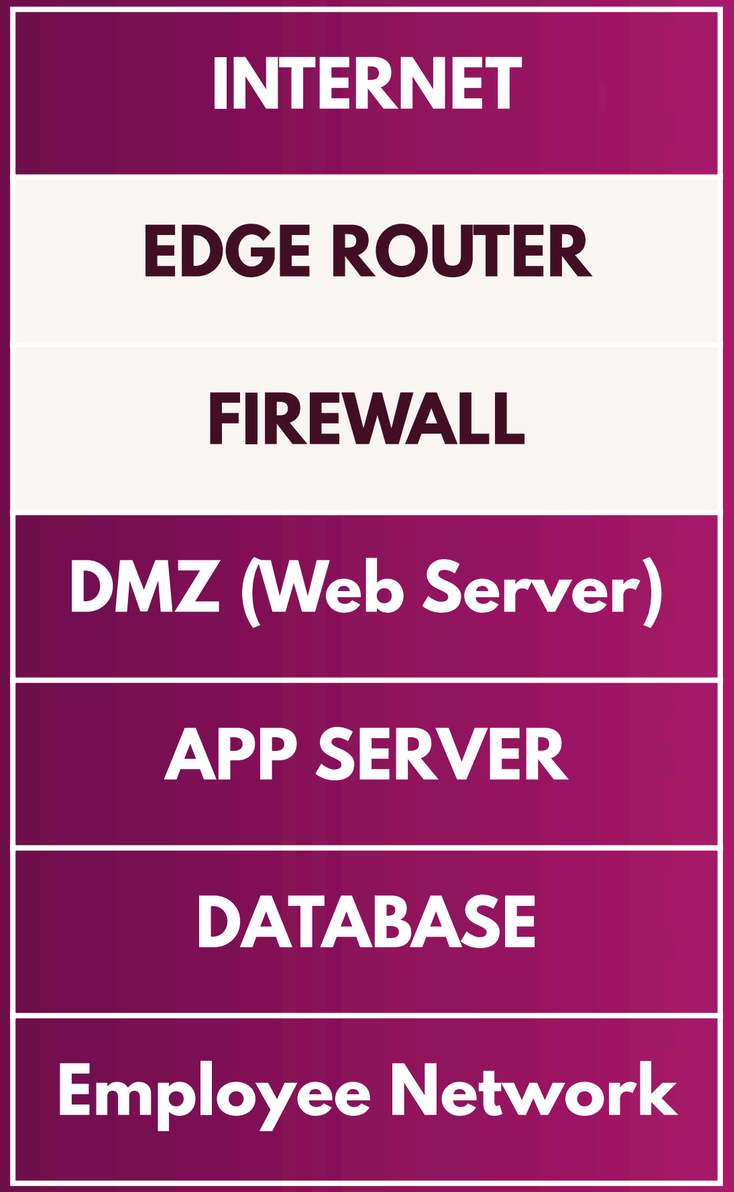
Finding: Port 443 Open

Defense Layer:
Perimeter Firewall



Initial Compromise

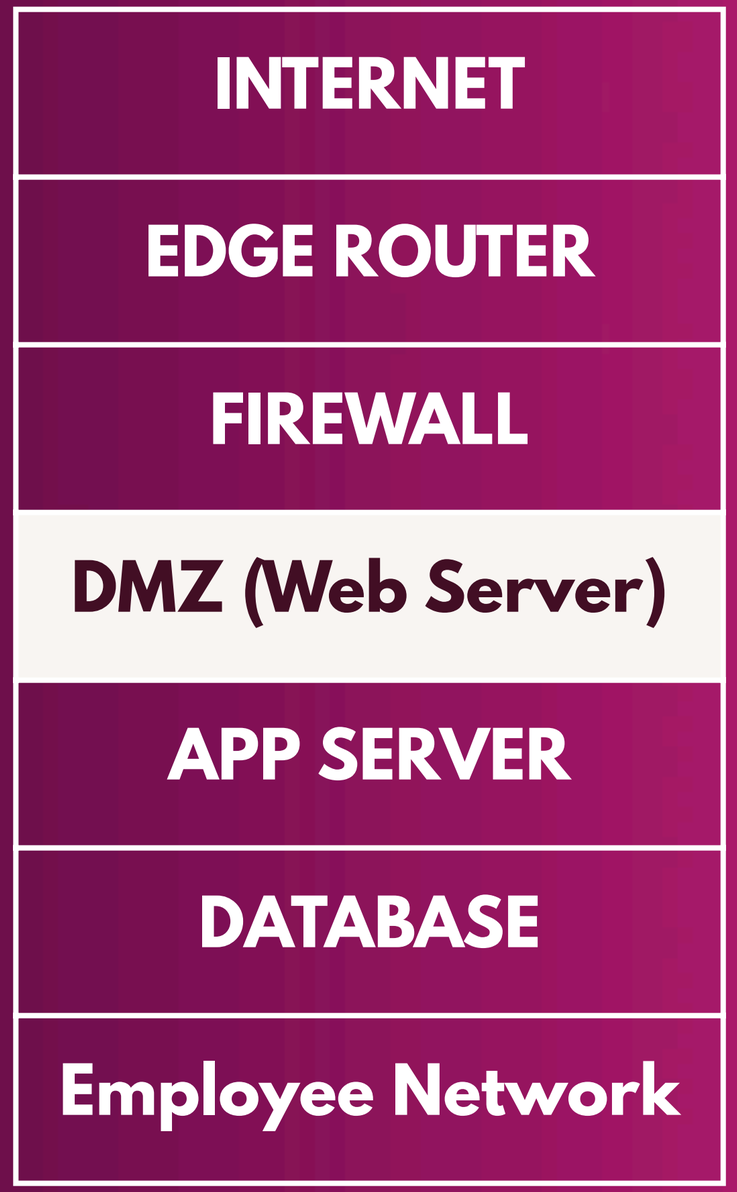
Finding:
Unpatched web framework



Persistence

- Install backdoor
- Create scheduled task
- Establish outbound C2

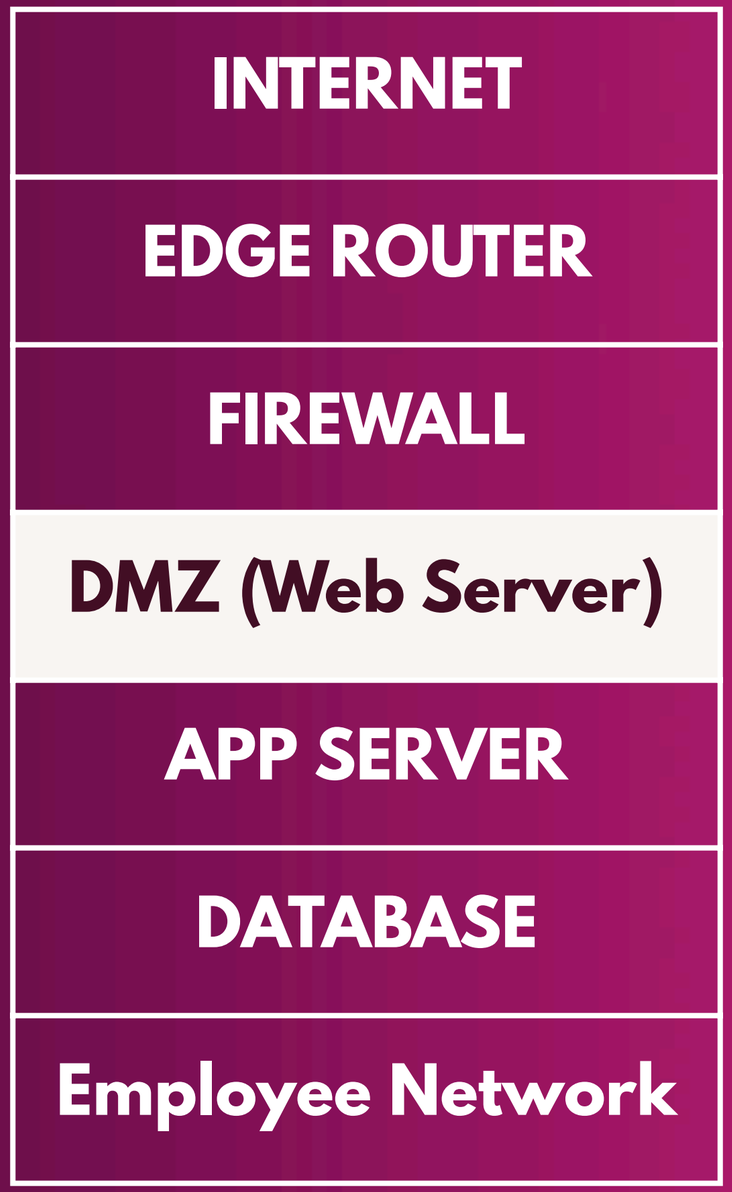
Defense Layer:
Host Hardening + EDR + Egress Filtering



Internal Recon

- Scan internal subnets
- SMB enumeration
- Domain controller discovery

Defense Layer: Segmentation

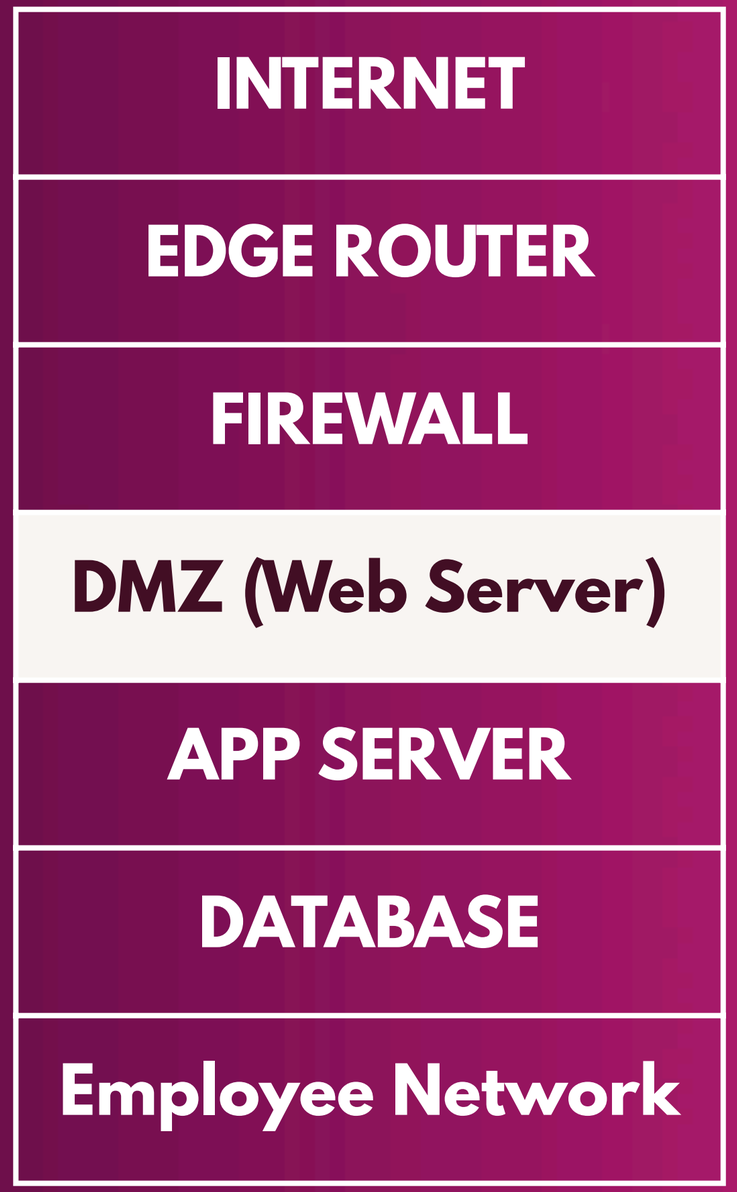


Demilitarized Zone

- Attempted access to App Server
- Employee Network blocked

- VLAN isolation
- East-west traffic restriction
- Zero trust

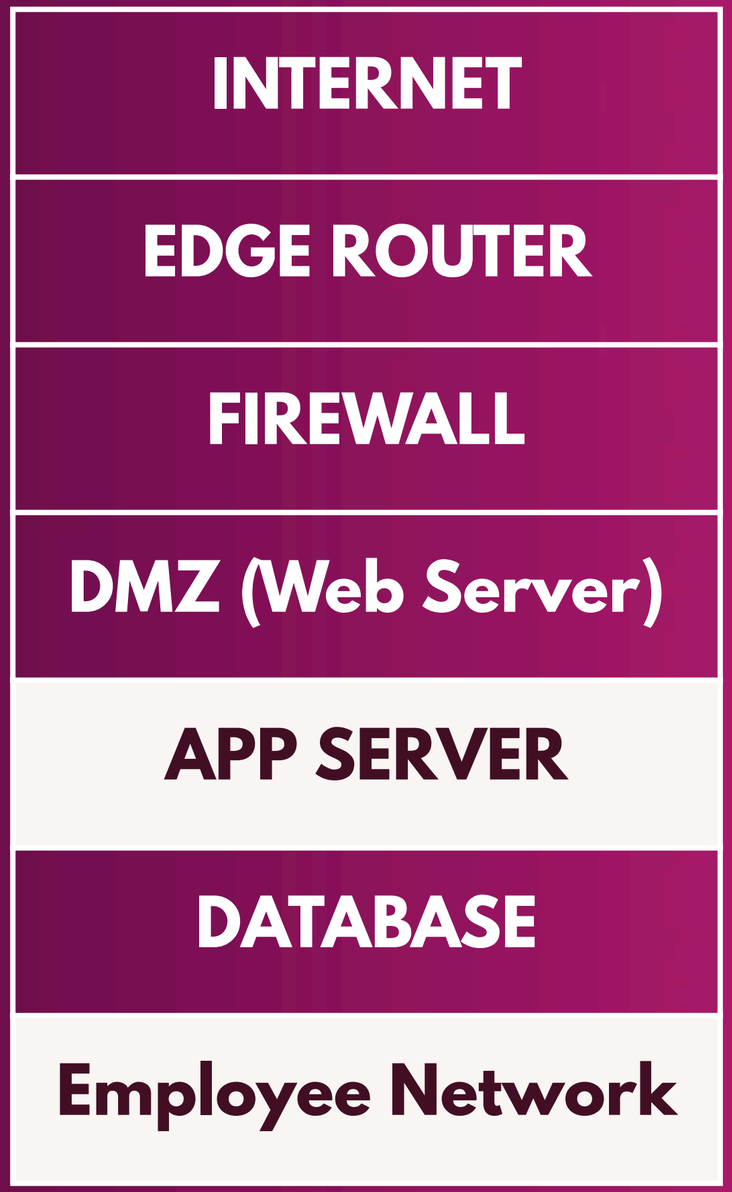
} DMZ



Lateral Movement

Defense Layer:

- Segmentation
- Strict port allow rules
- Zero trust network policy

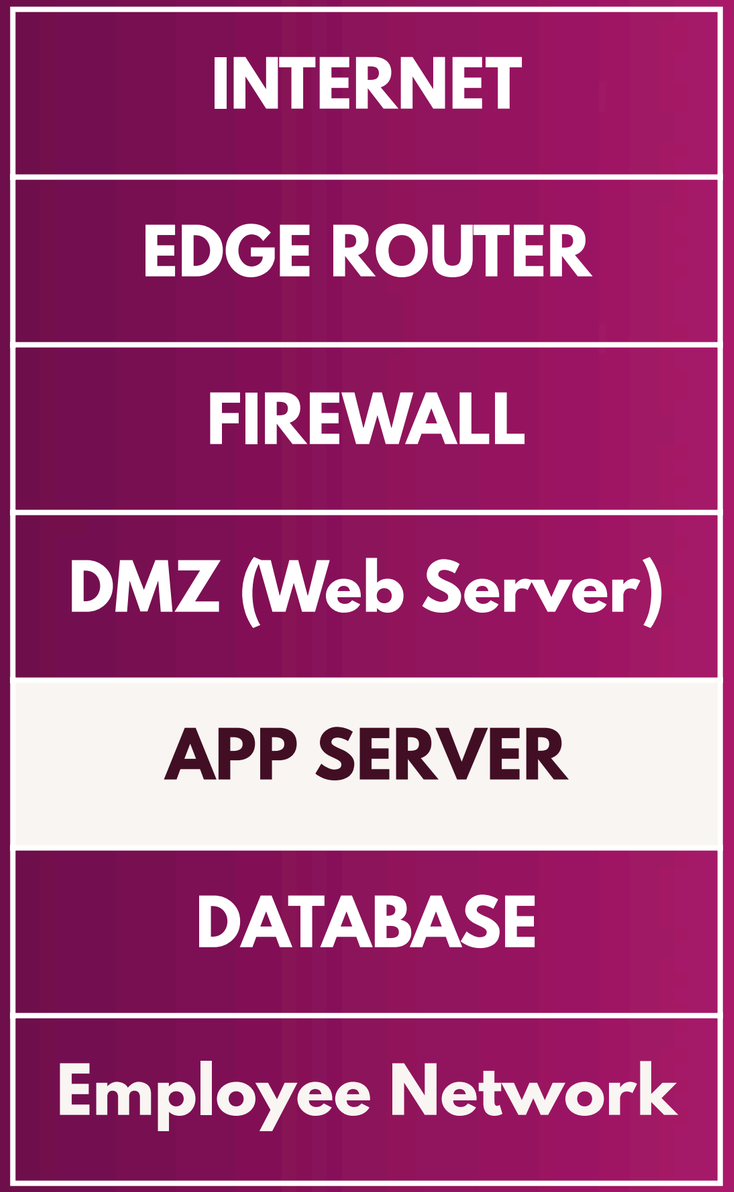


Application Layer Barrier

Finding:
database credentials in config file

Layer :

- Least privilege DB account
- Database access control
- Network rule allowing DB access only from App Server

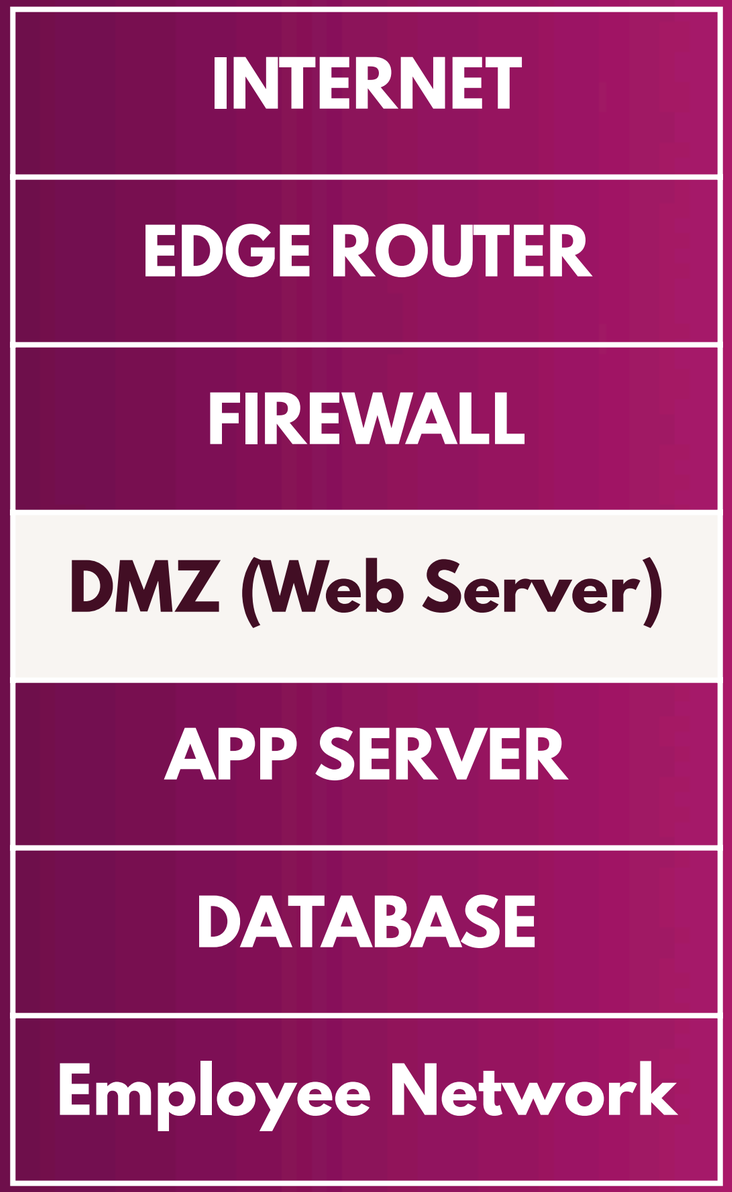


Privilege Escalation

- Escalate to admin
- Dump credentials
- Access broader data

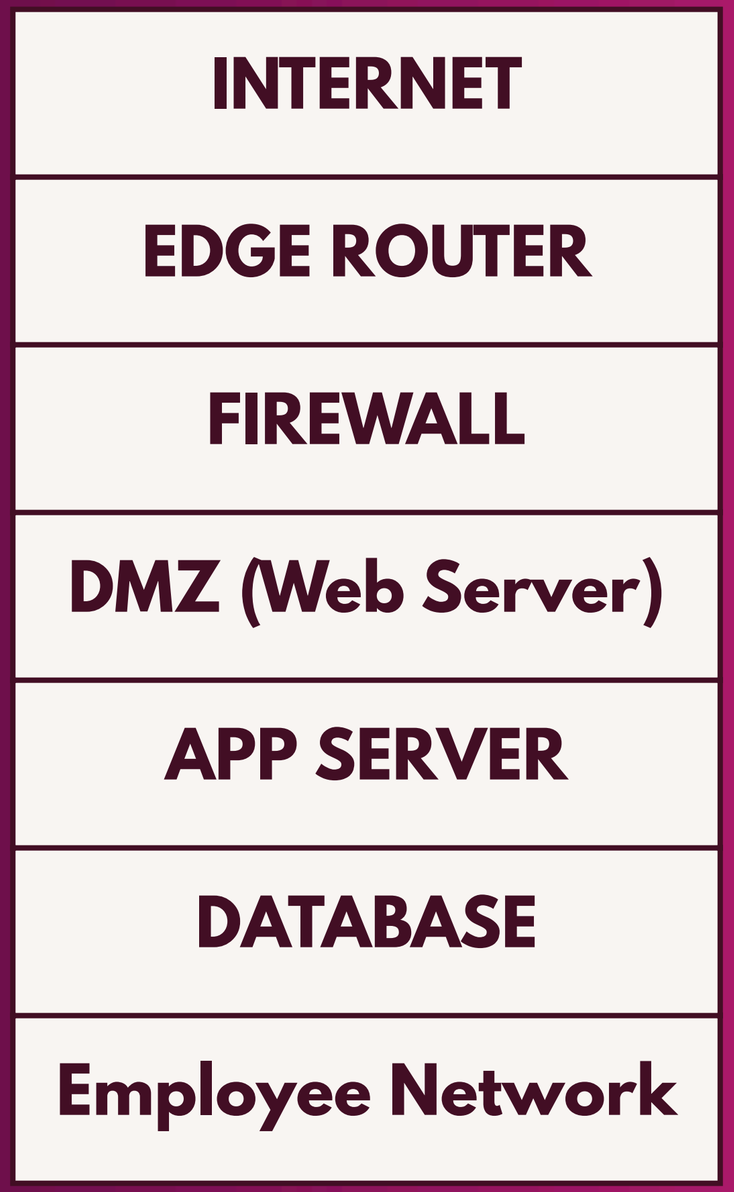
Defense Layer:

- RBAC
- Minimal service account permissions
- Credential isolation
- No domain admin reuse



Security Team Response

- SIEM
- EDR
- Firewall logs
- Database logs



Defense in Depth

- Perimeter control
- Segmentation
- Privilege limitation
- Host protection
- Monitoring
- Response